TUGAS KELOMPOK
TOPIK KHUSUS SC & KV



Disusun oleh:

1. Christiano Bryan Budiiman (24060123130079)
2. Cipta Fikri Wiratama (24060123140172)
3. Khairiya Fatih Izzudin Emarin (24060123140166)
4. Dewangga Ramadhan Halim (24060124130118)
5. Moses Morell Yosefan (24060124130094)

Dosen Pengampu:

Guruh Aryotejo, S.Kom., M.Sc.

DEPARTEMEN INFORMATIKA

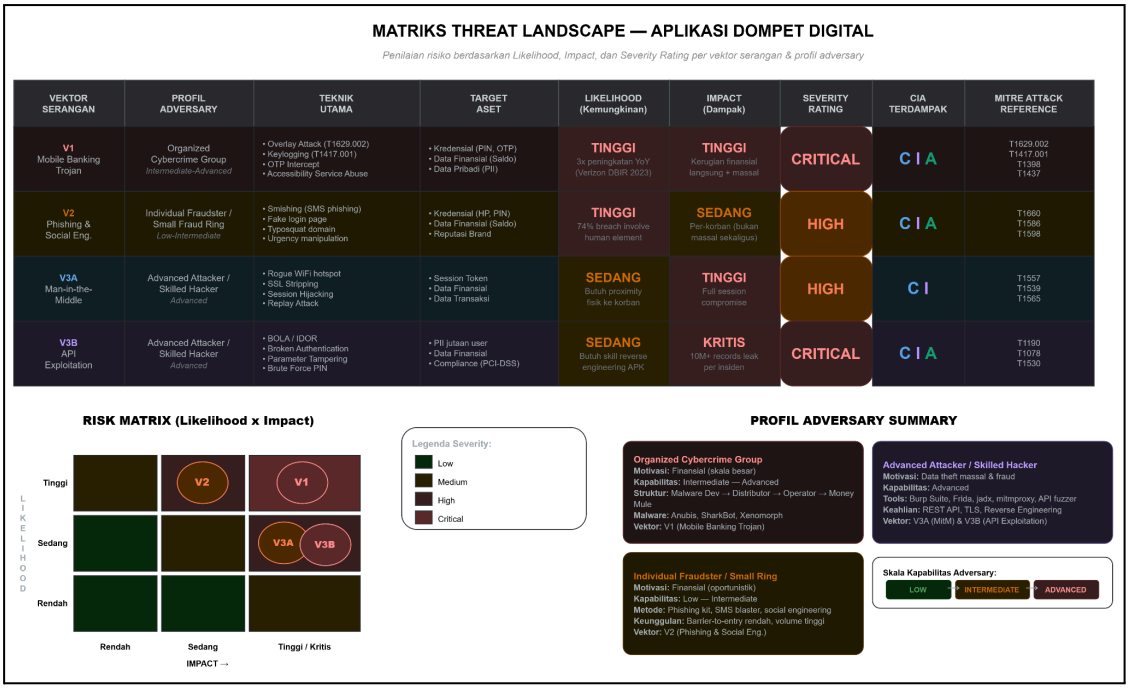
FAKULTAS SAINS DAN MATEMATIKA

UNIVERSITAS DIPONEGORO

2026

DIAGRAM

1. Matriks Threat Landscape



Matriks Threat Landscape memetakan empat vektor serangan utama terhadap aplikasi dompet digital beserta profil adversary, teknik eksploitasi, aset target, dan penilaian risiko. Setiap vektor dinilai berdasarkan dua dimensi: Likelihood (seberapa besar kemungkinan serangan terjadi) dan Impact (seberapa parah dampaknya jika berhasil). Kombinasi keduanya menghasilkan Severity Rating di mana V1 (Mobile Banking Trojan) dan V3B (API Exploitation) masuk kategori CRITICAL karena keduanya berpotensi menyebabkan kerugian finansial massal dan kebocoran data jutaan pengguna sekaligus.

Risk Matrix 3x3 di bagian bawah memvisualisasikan posisi relatif setiap vektor: V1 dan V2 berada di baris Likelihood Tinggi karena tren peningkatan 3x YoY (Verizon DBIR 2023) dan fakta bahwa 74% breach melibatkan faktor manusia, sedangkan V3A dan V3B berada di baris Likelihood Sedang karena membutuhkan keahlian teknis tinggi (reverse engineering, proximity fisik). Profil adversary juga dipetakan mulai dari sindikat terorganisir bermotif finansial (V1), penipu individu berskala kecil (V2), hingga hacker berpengalaman dengan tools canggih seperti Burp Suite dan Frida (V3A/V3B) sehingga terlihat jelas bahwa ancaman datang dari berbagai level kapabilitas yang memerlukan strategi mitigasi berbeda.

2. Diagram Alur Serangan

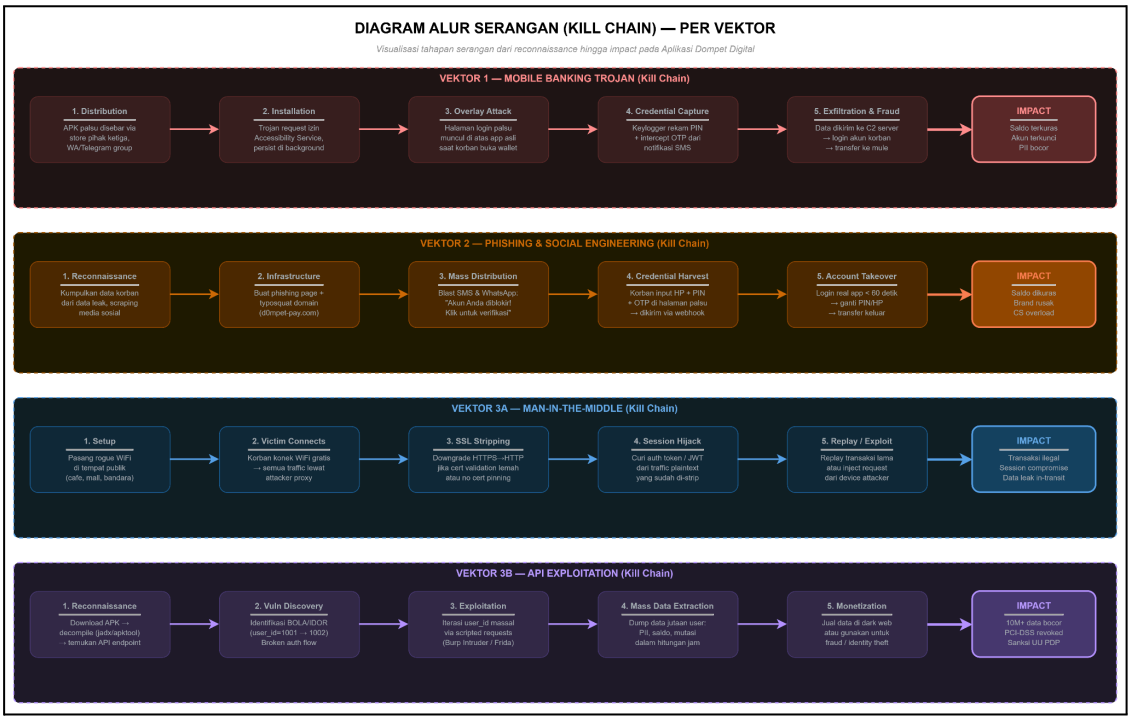


Diagram Alur Serangan menampilkan tahapan kronologis (kill chain) dari masing-masing empat vektor serangan, mulai dari fase persiapan awal hingga dampak akhir. Setiap baris merepresentasikan satu vektor dengan 5 tahap operasional ditambah kolom IMPACT: V1 dimulai dari distribusi APK palsu hingga exfiltration ke C2 server; V2 dari reconnaissance data korban hingga account takeover dalam waktu kurang dari 60 detik; V3A dari pemasangan rogue WiFi hingga replay attack; dan V3B dari decompile APK hingga monetisasi data curian di dark web.

Visualisasi kill chain ini penting untuk mengidentifikasi titik intervensi di setiap tahap misalnya, serangan V1 bisa dicegah di tahap Installation dengan root/jailbreak detection, V2 bisa dipotong di tahap Distribution dengan DMARC/domain monitoring, V3A bisa diblokir di tahap SSL Stripping dengan certificate pinning, dan V3B bisa dihentikan di tahap Exploitation dengan rate limiting dan proper authorization di API gateway. Dengan memahami urutan temporal setiap serangan, tim keamanan dapat merancang kontrol berlapis (defense-in-depth) yang menargetkan multiple kill chain stages sekaligus, sehingga kegagalan satu kontrol tidak langsung berakibat pada breach total.

RANCANGAN KONTROL PERTAHANAN BERLAPIS

Mengingat ketiga vektor ancaman yang telah diidentifikasi menyasar lapisan arsitektur sistem yang berbeda — yaitu perangkat klien, jalur otentikasi identitas, dan infrastruktur backend — maka penerapan satu jenis kontrol keamanan tunggal tidak memadai untuk memitigasi risiko secara komprehensif. Oleh karena itu, rancangan kontrol pada bab ini disusun berdasarkan prinsip defense-in-depth, yang mengintegrasikan empat pilar pertahanan, yaitu Teknologi, Tindakan Operasional, Proses Tata Kelola, dan Skema Pencadangan (Backup), yang diterapkan secara spesifik pada masing-masing vektor.

Vektor Ancaman	Pilar Kontrol	Uraian Rancangan Kontrol
Vektor 1 — Mobile Banking Trojan & Overlay Attack (Sisi Client)	**Teknologi**	Kontrol teknis utama yang direkomendasikan adalah penerapan Runtime Application Self-Protection (RASP), yaitu mekanisme perlindungan yang tertanam langsung di dalam kode aplikasi sehingga aplikasi memiliki kemampuan mendeteksi anomali proses secara mandiri, termasuk upaya code injection, debugging tidak sah, maupun keberadaan overlay window aktif di atas antarmuka aplikasi. Apabila anomali terdeteksi, sistem menghentikan sesi aplikasi secara otomatis guna mencegah eksfiltrasi data. Diperlukan pula filter anti-tapjacking yang menolak input pengguna apabila terdeteksi keberadaan jendela aplikasi lain yang menutupi tampilan asli, serta hardware-backed keystore untuk menyimpan kredensial biometrik lokal sebagai pengganti OTP berbasis SMS yang rentan intersepsi.
	Tindakan Operasional	Langkah operasional mencakup pembatasan instalasi aplikasi (sideloading) dari sumber di luar toko aplikasi resmi untuk kategori aplikasi finansial kritikal, pendeteksian dan pencabutan otomatis izin Accessibility Service yang teridentifikasi mencurigakan, serta penyelenggaraan program edukasi berkelanjutan kepada nasabah mengenai risiko instalasi berkas APK dari sumber tidak resmi.
	Proses Tata Kelola	Diperlukan prosedur operasional standar (SOP) untuk verifikasi keaslian aplikasi melalui pemeriksaan code signing sebelum setiap rilis produksi, pembaruan basis data signature malware perbankan secara berkala melalui siklus threat intelligence, serta prosedur eskalasi insiden yang terdefinisi secara jelas apabila sistem mendeteksi pola transaksi yang mengindikasikan aktivitas Automated Transfer System (ATS).

	Skema Pencadangan	Kontrol pencadangan mencakup penyimpanan log transaksi secara real-time ke media penyimpanan terpisah yang bersifat immutable (Write Once Read Many) untuk mendukung proses forensik digital pascainsiden, serta penerapan mekanisme hold dan rollback otomatis terhadap transaksi yang teridentifikasi anomali sebelum proses settlement final dilakukan.
Vektor 2 — Phishing & Adversary-in-the-Middle Reverse Proxy (Jalur Identitas)	**Teknologi**	Kontrol paling signifikan pada vektor ini adalah migrasi menuju autentikasi FIDO2/WebAuthn Passkeys. Karakteristik utama teknologi ini bersifat origin-bound, yaitu kunci kriptografis hanya dapat berfungsi apabila domain yang diakses identik dengan domain resmi yang telah terdaftar, sehingga meskipun korban tanpa disadari mengakses domain hasil typosquatting, mekanisme otentikasi akan menolak proses verifikasi secara otomatis — berbeda secara fundamental dengan skema OTP konvensional yang tetap dapat diteruskan pelaku melalui reverse proxy tanpa terdeteksi. Kontrol pelengkap berupa Mutual TLS (mTLS) juga direkomendasikan untuk mengikat token otentikasi merchant pada sertifikat digital perangkat tertentu.
	Tindakan Operasional	Tindakan operasional mencakup penerapan Impossible Travel Detection oleh tim Security Operations Center (SOC) untuk mendeteksi anomali perubahan geolokasi IP yang tidak wajar secara temporal, pemblokiran proaktif domain hasil typosquatting melalui prosedur DNS takedown, serta pelatihan kesadaran keamanan siber (security awareness training) yang ditujukan khusus kepada staf finansial merchant sebagai kelompok target utama serangan spear phishing.
	Proses Tata Kelola	Kebijakan tata kelola yang direkomendasikan meliputi kewajiban penerapan FIDO2 bagi seluruh akun yang memiliki hak akses untuk mengubah data rekening settlement, serta penerapan prinsip verifikasi ganda (dual-control atau maker-checker) yang mensyaratkan persetujuan dari sedikitnya dua pihak berbeda sebelum perubahan rekening pencairan dana dapat disahkan.
	Skema Pencadangan	Kontrol pencadangan mencakup penyimpanan log sesi otentikasi secara terpisah dengan periode retensi audit trail yang memadai, serta kemampuan melakukan rollback terhadap perubahan data rekening settlement dalam rentang waktu tertentu

		apabila kemudian terbukti merupakan hasil tindak penipuan.
Vektor 3 — Layer 7 API Flooding (Infrastruktur Backend)	**Teknologi**	Kontrol teknologi utama yang direkomendasikan adalah implementasi Anycast Cloud Web Application Firewall (WAF), yang berfungsi menyaring trafik berbahaya dalam skala besar pada titik masuk jaringan global (edge) sebelum trafik tersebut mencapai server asal (origin server). Hal ini krusial mengingat volume serangan yang tercatat mencapai puluhan ribu request per detik, suatu skala yang tidak dapat ditangani secara memadai oleh infrastruktur internal semata. Kontrol pelengkap berupa Adaptive Rate Limiting juga diperlukan untuk membatasi frekuensi permintaan maksimal per entitas atau token pada endpoint yang bersifat sensitif secara komputasi.
	Tindakan Operasional	Tindakan operasional mencakup penerapan mekanisme autoscaling pada connection pool basis data serta penerapan pola circuit breaker yang memungkinkan sistem menolak permintaan baru secara terkendali ketika beban mendekati kapasitas maksimal, alih-alih membiarkan keseluruhan sistem mengalami kegagalan total. Diperlukan pula pemantauan volume request per detik (RPS) secara real-time disertai mekanisme peringatan dini sebelum kuota koneksi basis data terlampaui.
	Proses Tata Kelola	Diperlukan penyusunan runbook tanggap insiden khusus skenario serangan penolakan layanan terdistribusi (DDoS) dengan target Recovery Time Objective (RTO) yang terdefinisi secara kuantitatif, serta pelaksanaan pengujian beban (load testing) dan simulasi meja (tabletop exercise) secara berkala untuk menguji ketahanan sistem terhadap skenario pembanjiran trafik.
	Skema Pencadangan	Kontrol pencadangan mencakup penggunaan Message Queue Buffer (seperti Kafka atau RabbitMQ) untuk menampung notifikasi transaksi (webhook) secara asinkron sehingga data transaksi tidak hilang selama terjadi lonjakan trafik ekstrem, serta penerapan replikasi basis data pada beberapa wilayah geografis (multi-region) untuk mendukung mekanisme failover otomatis apabila server asal mengalami kelumpuhan total.

LINK CHAT

Transkrip Interaksi AI

Catatan Evaluasi Kritis:

Penggunaan AI dalam proses penyusunan tugas ini terbukti memberikan akselerasi yang sangat signifikan, terutama dari segi efisiensi waktu dan tenaga. AI mampu mengeksekusi tugas-tugas teknis dan pengetikan teks ratusan kali lebih cepat dibandingkan kemampuan manual manusia. Selain itu, AI sangat efektif berperan sebagai mitra *brainstorming* untuk memetakan alur logika serangan, memberikan alternatif solusi mitigasi, serta menyusun struktur ide awal secara lebih rapi dan terarah.

Namun, evaluasi kritis menunjukkan adanya keterbatasan mendasar pada cara kerja AI. Ketika AI diberikan instruksi (*prompt*) yang bersifat umum tanpa menyertakan konteks spesifik, respons yang dihasilkan cenderung dangkal, keliru, dan tidak relevan dengan kebutuhan kasus yang dianalisis. AI sangat bergantung pada detail petunjuk yang diberikan oleh penggunanya. Tanpa *prompt* yang terstruktur, spesifik, dan kaya akan konteks operasional, AI tidak mampu menghasilkan keluaran yang akurat.

Hal ini membuktikan bahwa keberadaan manusia (*human-in-the-loop*) belum dapat tergantikan oleh AI. AI pada dasarnya hanyalah sebuah alat bantu yang pasif. Manusia tetap memegang kendali penuh sebagai pengarah, penyetir, sekaligus verifikator utama yang memberikan konteks, membatasi kerangka berpikir, dan menyaring keluaran AI agar tidak melebar keluar dari topik atau memberikan informasi yang keliru.

DAFTAR PUSTAKA

[1] S. Bojjagani and V. N. Sastry, "VAPTAi: A Threat Model for Vulnerability Assessment and Penetration Testing of Android and iOS Mobile Banking Apps," in *Proc. 2017 IEEE 3rd Int. Conf. Collab. Internet Comput. (CIC)*, San Jose, CA, USA, 2017, pp. 77–86. Available: https://ieeexplore.ieee.org/document/8181483.

[2] F. Mohsen, H. Bisgin, Z. Scott, and K. Strait, "Detecting Android Malwares by Mining Statically Registered Broadcast Receivers," in *Proc. 2017 IEEE 3rd Int. Conf. Collab. Internet Comput. (CIC)*, San Jose, CA, USA, 2017, pp. 67–76. Available: https://ieeexplore.ieee.org/document/8181482.

[3] Y. Fratantonio, C. Qian, S. P. H. Chung, and W. Lee, "Cloak & Dagger: From Two Permissions to Complete Control of the UI Feedback Loop," in *Black Hat USA 2017*, Tech. Rep. / White Paper, 2017. [Online]. Available: https://blackhat.com/docs/us-17/thursday/us-17-Fratantonio-Cloak-And-Dagger-From-Two-Permissions-To-Complete-Control-Of-The-UI-Feedback-Loop-wp.pdf.

[4] H. Xu, M. Yao, R. Zhang, M. M. Dawoud, J. Park, and B. Saltaformaggio, "DVa: Extracting Victims and Abuse Vectors from Android Accessibility Malware," in *Proc. 33rd USENIX Security Symp. (USENIX Security 24)*, Philadelphia, PA, USA, 2024, pp. 2611–2628. [Online]. Available: https://www.usenix.org/conference/usenixsecurity24/presentation/xu-haichuan.

[5] P. Čisar and S. M. Čisar, "The framework of runtime application self-protection technology," in *Proc. 2016 IEEE 17th Int. Symp. Comput. Intell. Informatics (CINTI)*, Budapest, Hungary, 2016, pp. 241–246. Available: https://ieeexplore.ieee.org/document/7846383.

[6] N. Bindel, C. Cremers, and M. Zhao, "FIDO2, CTAP 2.1, and WebAuthn 2: Provable Security and Post-Quantum Instantiation," in *Proc. 2023 IEEE Symp. Secur. Privacy (SP)*, San Francisco, CA, USA, 2023, pp. 434–451. Available: https://ieeexplore.ieee.org/document/10179454.

[7] Y. Huang, C. Shi, J. Lu, H. Li, H. Meng, and L. Li, "Detecting Broken Object-Level Authorization Vulnerabilities in Database-Backed Applications," in *Proc. 2024 ACM SIGSAC Conf. Comput. Commun. Secur. (CCS '24)*, Salt Lake City, UT, USA, 2024, pp. 3173–3187. DOI: https://doi.org/10.1145/3658644.3690227.

[8] S. T. Zargar, J. B. D. Joshi, and D. Tipper, "A Survey of Defense Mechanisms Against Distributed Denial of Service (DDoS) Flooding Attacks," *IEEE Commun. Surv. Tutorials*, vol. 15, no. 4, pp. 2046–2069, 2013. DOI: https://doi.org/10.1109/SURV.2013.031413.00127.

[9] F. Montesi and J. Weber, "From the Decorator Pattern to Circuit Breakers in Microservices," in *Proc. 10th ACM SIGPLAN Int. Conf. Softw. Lang. Eng. (SLE 2017)*, Vancouver, BC, Canada, 2017, pp. 230–234. Available: https://www.fabriziomontesi.com/files/mw18.pdf.

[10] N. Jeršič, M. Turkanović, and T. Beranič, "Towards a Sustainable Cybersecurity Governance: Threat Modelling with Large Language Models," *Sustainability*, vol. 17, no. 23, Art. no. 10569, 2025. DOI: https://doi.org/10.3390/su172310569.